सत्यमेव जयते

Application Security Test Report
(First Round)
Of
Video Management System
Of
Ajeevi Technologies Pvt. Ltd.

(Staging URL: https://gyanakshi.com/login)

9th Sept, 2026

STQC IT - ERTL (North),
STQC Directorate,
Ministry of Electronics & Information Technology,
ERTL (North), S- Block, Okhla Industrial Area Phase - II,
New Delhi - 110020

STQC IT - ERTL (North) APPLICATION SECURITY TEST REPORT			
SRF & Proposal No.	**Security Test Report Number**	**Date**	**Page**
STQC IT – ERTL(N))/Ajeevi Technologies Pvt. Ltd./Video Management Analytics/Web Application/08/2026/Proposal/41	STQC IT-ERTL(N)/Ajeevi Technologies Pvt. Ltd./Video Management Analytics/Website /AS/VR/09/2026/064	09/09/2026	1 of 14

ज्ञापन
MEMORANDUM

1. यह परीक्षण रिपोर्ट एस.टी.क्यू.सी आईटी, इलेक्ट्रॉनिकी क्षेत्रीय परीक्षण प्रयोगशाला (उत्तर) (इ.क्षे.प.प्र(उ.)) मा.प.गु.प्र निदेशालय, इलेक्ट्रॉनिकी व सूचना प्रौद्धिगिकी मंत्रालय, भारत सरकार व्दारा जारी की गई है।
This Test is issued by STQC IT, ELECTRONICS REGIONAL TEST LABORATORY (NORTH) (ERTL) (N), under STQC Directorate, Ministry of Electronics and Information Technology, Government of India.

2. यह रिपोर्ट परीक्षण/आडिट किये गये विशेष साफ्टवेयर/सिस्टम के परीक्षण/आडिट परिणाम का रिकार्ड है। यह अन्य उन साफ्टवेयर/सिस्टम पर भी लागू नही है जो उस विशेष उत्पाद के समान घोषित किये गए है।
This test Report is the record of results of testing/audit pertaining to the particular software/system tested/audited by laboratory and do not apply to other software/system even though declared to be identical.

3.जारी परीक्षण रिपोर्ट आंशिक रूप में केवल निदेशक इ.क्षे.प.प्र(उ) की लिखित अनुमति एवं स्वीकृति के उपरान्त ही दुबारा जारी किया जा सकता है।
This Test Report shall not be reproduced, except in full, unless written permission for the publication of an approved abstract has been obtained from the Director, ELECTRONICS REGIONAL TEST LABORATORAY (NORTH), NEW DELHI.

4.परीक्षण रिपोर्ट में दिए परिणाम केवल उसी समय एवं मापन अवस्था के समय ही वैध होंगे।
Results reported, in this test report are valid at the time of and under the static condition of measurement.

5. परीक्षण/आडिट पर्यवेक्षण आंकडों में परिवर्तन के लिये एस.टी.क्यू.सी.आई.टी,इ.क्षे.प.प्र.(उ),नई दिल्ली, उत्तरदायी नही होगी।
STQC IT, ERTL (N), New Delhi shall not be liable for any change in the test/ audit observations.

6.यह परीक्षण/आडिट रिपोर्ट किसी कानूनी उद्देश्य में प्रयोग किये जाने के लिये नहीं हैं तथा इसे न्यायलय में प्रस्तुत नही किया जा सकता।
This Test /audit Report is not to be used for any legal purpose and shall not be produced in court of law.

7.एस.टी.क्यू.सी.आई.टी, इ.क्षे.प.प्र(उ) नई दिल्ली अन्य पार्टी परीक्षण व आडिट सेवाए सुविधा उपलब्ध कराती है तथा किसी साफ्टवेयर/सिस्टम की स्वीकृति प्रदान नहीं करती है।
STQC IT, ERTL (N) provides third party testing and audit services and does not approve any software/system.

8.किसी प्रकार के विवाद के मामले में निदेशंक इ.क्षे.प.प्र (उ) नई दिल्ली का निर्णय ही अन्तिम व मान्य होगा।
In case of any dispute, the decision of the Director, ERTL (N), New Delhi shall be final and binding.

9. सामान्यत: ग्राहक की सहमति के बिना उस के व्दारा प्रयोगशाला में दी गई स्वामित्व सम्बंधित जानकारी, किसी अन्य पक्ष को नही दी जाती, जब तक कि सक्षमअधिकारी जनहित में उस जानकारी को दिये जाने के लिए सन्तुष्ट न हो।
In general proprietary Information submitted by customer, in the laboratory may not be provided to any third party without the consent of customer, unless until the competent authority is satisfied that the larger public interest warrants the disclosure.

10.प्रयोगशाला के व्दारा दी जाने वाली सेवाओं में सुधार के लिए कृप्या अपनी प्रतिक्रिया एवं सुझाव ग्राहक सेवा कक्ष मे उपलब्ध/रिपोर्ट के साथ संलग्न प्रतिक्रिया फार्म में अथवा ई-मेल/ फेक्स/पत्र के व्दारा प्रदान करें।आपके व्दारा दी गई समस्त जानकारी गोपनीय रखी जाएगी।
To help us improve our service, you are requested to please provide us your feedback/suggestion, either in the feedback form available in customer services cell send along with the report or through email/fax/letter. All the information provided by you will be kept confidential.

Executive Summary:

The application security testing of the **Gyanakshi** web application of **Ajeevi Technologies Pvt. Ltd.** was undertaken by STQC (**Service Request Form No: 2605902)**. The scope of testing covered only the web application & did not include any attempts to exploit network or host system level vulnerabilities. As the scope was limited to application security only, the configuration settings of host systems & network devices and operational aspects including security processes/ controls at hosting site were not verified.

The key aim of application security testing was to verify that it complies with the security requirements of OWASP Top 10, 2025. The website application security testing was performed to assess the adequacy & effectiveness of various security controls such as input validation, authentication, authorization, session management, data protection during transmission and in storage, error handling, audit logs etc. and identify the vulnerabilities (if any).

The application security testing was performed only on the test setup which was provided to STQC on a staging server and the application was accessed directly by using https://gyanakshi.com/login test URL with admin role (User id: admin@demo.com). Assessment of completeness and correctness of the functions implemented in the application was not carried out as it does not come under the scope of application security testing.

The Website Application Security Testing was carried out using black box approach based on test scenarios & test cases derived from the requirements of the application without any knowledge of the internals. Security testing was conducted without launching any attack; however, tests were conducted to determine whether the Website is susceptible to security vulnerabilities. The security testing involved an active analysis of Website to identify any weaknesses, technical flaws and vulnerabilities. The Website was tested as per the security requirements of OWASP Top 10, 2025.

During the proposal stage, the URL provided was http://14.195.152.244:9013/. However, during the testing phase, the URL was changed to https://gyanakshi.com/login. Therefore, all security testing was conducted on the revised URL, i.e., https://gyanakshi.com/login.

The Security vulnerabilities/ findings (observed through automated and manual testing) are given in section 4.0. For evidence of the vulnerabilities, please refer the attached snapshots in Annexure 'B' and the Tool reports shared along with this report.

1.0	**Client Details:**	
1.1	**Client**	AJEEVI Technologies Pvt. Ltd. (SATYA SRF: 26SRF02319)
1.2	**Address**	505, Advant Navis Business Park Tower-A1, Corporate Park, Sector 142, Noida, Uttar Pradesh 201304. Contact Details: Vishal Gupta, 9654323500, vishal.gupta@ajeevi.com
2.0	**Details of the Web Application Under Test:**	
2.1	**Web Application**	Video Management System (Gyanakshi)
2.2	**Version No.**	1.0
2.3	**Date of Release**	11-Aug-2026
2.4	**Description**	The web application enables to add cameras, nvr to view to live streaming, recording and perform analytic, with alerts, and ticket management.
2.5	**Developing Organization**	AJEEVI Technologies Pvt. Ltd.
2.6	**Applicable References**	OWASP Top 10, 2025
2.7	**Web Application Access**	https://gyanakshi.com/login
2.8	**Documents Submitted**	Website Application Security Questionnaire
3.0	**Test Description:**	
3.1	**Testing Organization**	STQC IT - ERTL (North), STQC Directorate, Ministry of Electronics &Information Technology, ERTL (North), S- Block, Okhla Industrial Area Phase – II, New Delhi – 110020
3.2	**Test Objective(s)**	**The key aim of security testing was to verify the Web application of AJEEVI Technologies Pvt. Ltd. complies with the security requirements as per OWASP top 10, 2025.** The Application Security testing was performed to assess the adequacy & effectiveness of various software application security controls such as input validation, authentication, authorization, session management, denial of service, data protection during transmission and in storage, error handling, audit logs etc. and identify vulnerabilities (if any).
3.3	**Scope of Testing**	The scope of testing covered the Web application of AJEEVI Technologies Pvt. Ltd. & did not include any attempts to exploit network or host system level vulnerabilities. As the scope was limited to application security only, the configuration settings of host systems & network devices and operational aspects including security processes/ controls at hosting site were not verified.
3.4	**Type of Testing**	Independent third party Application Security Testing.
3.5	**Test Approach & Methodology**	Application security testing involved an active analysis of the web application to identify any weaknesses, technical flaws and known vulnerabilities using automated tool and manual testing.

3.6	**Test Data**	The test data used for testing was generated based on test scenarios for both valid as well invalid cases.
3.7	**Test Standards**	1. IEEE Std29119-3 for test documentation 2. OWASP Top 10, 2025
3.8	**Test Environment**	The client side test environment used for security testing comprised of following hardware & software Test configurations:
	Hardware & Software Configurations	System Model: HP Processor: Intel(R) Core(TM) i7-8700 CPU @ 3.20GHz 3.19 GHz RAM: 16 GB HDD: 1 TB
		OS Name: Microsoft Windows 11 Pro Chrome v 130.0.6723.117 (Official Build) (64-bit) Microsoft Office Open Source Proxy Interceptor Tool
	Test Tools	HCL AppScan (v 10.11.1), testssl (v 3.2.2) and Burp suite (v 2026.7.3).
3.9	**Test Location**	STQC IT - ERTL (North), STQC Directorate, Ministry of Electronics & Information Technology, ERTL (North), S- Block, Okhla Industrial Area Phase – II, New Delhi – 110020
3.10	**Test Team**	Dr. Arvind Kumar, Scientist 'B' Nishu Kumar, Scientific Assistant
3.11	**Period of Testing**	First Cycle: 18.08.2026 to 20.08.2026, 31.08.2026, 07.09.2026 and 09.09.2026.

4.0. Application Security Test Summary:

S. No.	Vulnerability Details
1.	**Vulnerable Component** During the security assessment, it was observed that the application is using an outdated version of the third-party React component, i.e., React 19.1.0. The use of an outdated component may expose the application to known security vulnerabilities associated with that version. To address this issue, it is recommended to upgrade React to the latest stable and security-supported version and ensure that all associated dependencies are also kept up to date. **Vulnerable URL:** https://gyanakshi.com/assets/index-DFuBniBY.js There could be more vulnerable URL/Components. **For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'B')**
2.	**Check for SRI (Subresource Integrity) support** During the security assessment, SRI (Subresource Integrity) not supported was detected by AppScan. In case the third-party server is compromised, the content/behavior of the site will change. To address this issue, it is recommended to add to each third-party script/link element support to SRI (Subresource Integrity). **Vulnerable URL:** https:/gyanakshi.com/login There could be more vulnerable URL/Components. **For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'B')**
3.	**Missing Cross-Origin-Embedder-Policy (COEP) header** During the security assessment, it was observed that the Cross-Origin-Embedder-Policy (COEP) HTTP response header is missing from the application. The absence of this security header means that the application does not explicitly enforce a cross-origin embedding policy, which may increase the risk of unintended interactions with cross-origin resources and prevent the application from benefiting from browser-enforced cross-origin isolation. To address this issue, it is recommended to configure an appropriate Cross-Origin-Embedder-Policy (COEP) header. Recommended Configuration: Cross-Origin-Embedder-Policy: require-corp **Vulnerable URL:** https:/gyanakshi.com/login There could be more vulnerable URL/Components. **For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'B')**
4.	**Missing Cross-Origin-Opener-Policy (COOP) header** During the security assessment, it was observed that the application does not define the Cross-Origin-Opener-Policy (COOP) HTTP response header. The absence of the COOP header means that the application does not explicitly control the relationship between the browsing context of the application and cross-origin documents. This may increase the risk of unintended cross-origin interactions and prevents the application from benefiting from browser-enforced browsing-context isolation. To address this issue, it is recommended to configure an appropriate Cross-Origin-Opener-Policy (COOP) response header.

S. No.	Vulnerability Details
	Recommended Configuration: Cross-Origin-Opener-Policy: same-origin **Vulnerable URL:** https:/gyanakshi.com/login There could be more vulnerable URL/Components. **For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'B')**
5.	**Missing Cross-Origin-Resource-Policy (CORP) header** During the security assessment, it was observed that the application does not define the Cross-Origin-Resource-Policy (CORP) HTTP response header. The absence of the CORP header means that the application does not explicitly specify whether its resources may be requested by documents from other origins. Depending on the application's functionality and the nature of the resources being served, this may increase the risk of unintended cross-origin resource access. To address this issue, it is recommended to configure an appropriate Cross-Origin-Resource-Policy (CORP) response header based on the application's cross-origin requirements. Recommended Configuration: Cross-Origin-Resource-Policy: same-origin **Vulnerable URL:** https:/gyanakshi.com/login There could be more vulnerable URL/Components. **For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'B')**
6.	**Older TLS Version is Supported** During the security assessment, AppScan identified that the web server/application server supports older and deprecated TLS protocol versions, specifically TLS 1.0 and TLS 1.1. The use of deprecated TLS versions may weaken the overall security of encrypted communications and may expose the application to known protocol-level weaknesses. To address this issue, it is recommended to disable TLS 1.0 and TLS 1.1 on the web/application server and configure the server to support TLS 1.2 and TLS 1.3 using strong, modern cipher suites. **Vulnerable URL:** https:/gyanakshi.com/login There could be more vulnerable URL/Components. **For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'A' - Snapshots of vulnerabilities observed (Sr. No. 1) and Annx. 'B')**
7.	**SHA-1 cipher suites were detected** During the security assessment, AppScan identified that the web server/application server supports cipher suites that use the **SHA-1** hashing algorithm. SHA-1 is considered deprecated and is no longer recommended for modern cryptographic applications due to known weaknesses in its collision resistance. The use of such deprecated cryptographic algorithms may weaken the overall security of encrypted communications and increase the risk associated with the protection and integrity of transmitted information. To address this issue, it is recommended to review and update the server's TLS configuration by disabling SHA-1-based cipher suites and configuring the server to use strong, modern cipher suites and cryptographic algorithms, such as SHA-256 or stronger, where applicable. **Vulnerable URL:** https:/gyanakshi.com/login There could be more vulnerable URL/Components.

S. No.	Vulnerability Details
	For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'A' - Snapshots of vulnerabilities observed (Sr. No. 2) and Annx. 'B')
8.	**Missing HTTP Strict-Transport-Security Header** During the security assessment, it was observed that the application does not define HTTP Strict-Transport-Security Header. This misconfiguration may be possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations and persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc. To address this issue, it is recommended to implement the HTTP Strict-Transport-Security policy with a long "max-age". **Vulnerable URL:** https:/gyanakshi.com/ **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 3).**
9.	**Unnecessary HTTP Response Headers Disclosing Infrastructure Information** During the security assessment, it was observed that the application response contains HTTP response headers that disclose information about the underlying CDN/infrastructure and request-processing environment. For example, the following headers were identified: Server: cloudflare CF-Cache-Status: DYNAMIC CF-Ray: a3398576fb751658-SIN Report-To: {...} NEL: {...} To address this issue, it is recommended not to allow sensitive information to leak. **Vulnerable URL:** https:/gyanakshi.com/login There could be more vulnerable URL/Components. **For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'A' - Snapshots of vulnerabilities observed (Sr. No. 4) and Annx. 'B')**
10.	**Email Address Pattern Found** During the security assessment, AppScan identified an email address pattern within the application's response. The response contains an email address that may be considered private or sensitive, for example, admin@ajeevi.com. Disclosure of email addresses may provide information about the application's personnel, administrative accounts, or organizational structure and could potentially assist in targeted attacks such as phishing or account enumeration. To address this issue, it is recommended to review the identified email address and remove or avoid exposing email addresses in publicly accessible application responses where they are not required for application functionality. **Vulnerable URL:** https://gyanakshi.com/assets/index-DFuBniBY.js There could be more vulnerable URL/Components. **For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'B')**
11.	**Internal IP Disclosure Pattern Found** During the security assessment, AppScan identified an internal IP address pattern within the application's response. For example, the response contains the internal IP address 192.168.0.126. Disclosure of internal IP addresses may provide information about the application's internal network architecture and infrastructure. To address this issue, it is

S. No.	Vulnerability Details
	recommended to review the application responses and remove or mask internal IP addresses that are not required to be exposed to end users **Vulnerable URL:** https://gyanakshi.com/assets/index-DFuBniBY.js There could be more vulnerable URL/Components. **For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'B')**
12.	**Missing "Referrer policy" Security Header** During the security assessment, Burp Suite identified that the application's HTTP response does not include an appropriate Referrer-Policy security header. The absence of an explicit Referrer-Policy may allow browsers to disclose more referrer information than necessary when navigating from the application to another resource or origin. To address this issue, it is recommended to configure the web server/application to return an appropriate Referrer-Policy header. Recommended Configuration: Referrer-Policy: strict-origin-when-cross-origin **Vulnerable URL:** https:/gyanakshi.com/ There could be more vulnerable URL/Components. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 5).**
13.	**Non-Quantum-Resistant Cipher Suite(s) Detected** Non-Quantum-Resistant Cipher Suite(s) Detected was identified by AppScan. The application/server supports conventional TLS cipher suites that rely on classical cryptographic mechanisms and do not provide post-quantum/quantum-resistant key establishment. An attacker could potentially capture and retain encrypted network traffic today and attempt to decrypt the captured data in the future if sufficiently capable quantum computers become available. To address this issue, it is recommended to review and upgrade the TLS configuration to support post-quantum or hybrid post-quantum cryptographic mechanisms, where supported by the deployed TLS stack and infrastructure. Unnecessary legacy TLS 1.2 CBC cipher suites should also be disabled where compatibility requirements permit. **Vulnerable URL:** https:/gyanakshi.com/login There could be more vulnerable URL/Components. **For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'B')**
14.	**Possible Server Path Disclosure Pattern Found** During the security assessment, AppScan identified a possible server path disclosure pattern in the application's response. Disclosure of absolute server paths may provide information about the underlying file system structure, application installation directories, or server configuration. To address this issue, it is recommended to review the identified response and prevent the disclosure of absolute server paths, internal directory structures, and unnecessary filenames to end users. **Vulnerable URL:** https://gyanakshi.com/assets/index-DFuBniBY.js There could be more vulnerable URL/Components. **For complete list of URLs and more details please refer the AppScan reports enclosed. (Annx. 'B')**

S. No.	Vulnerability Details
15.	**Weak TLS Configuration: Obsolete CBC Cipher Suites Offered** During the security assessment, it was observed that the application offers obsolete CBC (Cipher Block Chaining) cipher suites, as identified in the testssl report. The use of weak or outdated TLS cipher suites may expose the application to cryptographic attacks such as padding oracle–based attacks, potentially compromising the confidentiality and integrity of encrypted communications. To mitigate this issue, it is strongly recommended to disable obsolete and weak CBC-based cipher suites; configure the server to support only strong, modern cipher suites (such as AES-GCM or ChaCha20-Poly1305); enforce TLS 1.2 and TLS 1.3; and follow industry best practices for secure TLS configuration. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 6).**
16.	**BREACH Offered** During the security assessment, it was observed that the application offers BREACH (Browser Reconnaissance and Exfiltration via Adaptive Compression of Hypertext) vulnerability, as identified in the testssl report. BREACH is a side-channel attack that can potentially allow an attacker to infer sensitive information from encrypted HTTPS responses by analyzing differences in the size of compressed responses. To mitigate this issue, it is strongly recommended to implement appropriate mitigations, such as: disable HTTP compression for responses containing sensitive information, avoid reflecting attacker-controlled input together with sensitive secrets in the same response, separate sensitive tokens from pages that contain user-controlled input, implement random padding in sensitive responses where appropriate, review the application's use of gzip/Brotli compression, and use appropriate CSRF protections and secure session management. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 7).**
17.	**BEAST Offered** During the security assessment, it was observed that the application offers BEAST (Browser Exploit Against SSL/TLS) vulnerability, as identified in the testssl report. BEAST is a cryptographic attack that primarily affects SSL/TLS implementations using TLS 1.0 with CBC (Cipher Block Chaining) mode cipher suites. Under certain conditions, an attacker positioned as a Man-in-the-Middle (MITM) may be able to exploit weaknesses in the CBC implementation and potentially recover sensitive information from encrypted communications. To mitigate this issue, it is strongly recommended to implement appropriate mitigations, such as: disable TLS 1.0 and other obsolete SSL/TLS protocols, Support only modern protocols, preferably TLS 1.2 and TLS 1.3, Disable unnecessary CBC-mode cipher suites, particularly for legacy TLS configurations, Prefer modern authenticated encryption cipher suites such as: AES-GCM and ChaCha20-Poly1305**,** Configure the server to use strong key exchange mechanisms such as ECDHE, Regularly review the SSL/TLS configuration according to current industry security standards and best practices and Test the server configuration after remediation using an appropriate SSL/TLS security assessment tool. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 8).**
18.	**LUCKY13 Offered** During the security assessment, it was observed that the application offers BREACH (Browser Reconnaissance and Exfiltration via Adaptive Compression of Hypertext) vulnerability, as identified in the testssl report. LUCKY13 is a timing-based cryptographic attack affecting

S. No.	Vulnerability Details
	certain implementations of TLS that use CBC-mode cipher suites with MAC-then-encrypt construction. To mitigate this issue, it is strongly recommended to implement appropriate mitigations, such as: disable unnecessary legacy CBC-mode cipher suites, prefer modern AEAD (Authenticated Encryption with Associated Data) cipher suites, use cipher suites based on: AES-GCM and ChaCha20-Poly1305**,** support modern TLS versions, preferably TLS 1.2 and TLS 1.3, ensure the underlying TLS library and server software are fully updated and include protections against known timing attacks and regularly review the SSL/TLS configuration according to current industry security best practices. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 9).**
19.	**Communication of credentials to back-end servers (DB/LDAP)** It was observed that the application communicates User ID and Password credentials to back-end servers, such as Database (DB) or LDAP servers, in plain text format. The credentials are not adequately protected through encryption during transmission. An attacker who gains access to the network traffic or communication channel may potentially intercept and obtain valid authentication credentials. To mitigate this issue, it is strongly recommended to use encrypted communication channels such as TLS/SSL for communication with DB and LDAP servers. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 10).**
20.	**Disabling Browser Autocomplete Feature** It was observed that the application does not disable the browser autocomplete feature for sensitive input fields. As a result, browsers may store and automatically populate previously entered information, such as usernames, passwords, or other sensitive data. To mitigate this issue, it is strongly recommended to review the use of browser autocomplete functionality for sensitive fields. For highly sensitive information, autocomplete should be appropriately controlled. Recommended Configuration: autocomplete="off".
21.	**Randomness of Session Token** During the security assessment, it was observed that the session tokens generated by the application exhibit poor randomness. Weak or predictable session identifiers can be guessed or reproduced by attackers, potentially allowing session hijacking and unauthorized access to user accounts. To mitigate this issue, it is strongly recommended to generate session tokens using cryptographically secure random number generators, ensure session identifiers are long, unique, and unpredictable, regenerate session identifiers after authentication and privilege changes, transmit session tokens only over secure channels (HTTPS), implement proper session expiration and invalidation mechanisms. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 11).**
22.	**Use of Secure Cookies** During the security assessment, it was observed that one or more cookies used by the application are not configured with the Secure attribute. The Secure attribute instructs the browser to transmit the cookie only over encrypted HTTPS connections. When this attribute is not enabled, cookies may potentially be transmitted over unencrypted HTTP connections if such connections are available. This could expose sensitive session information to interception through network-based attacks, such as Man-in-the-Middle (MITM) attacks. To mitigate this issue, it is strongly recommended to configure all sensitive cookies, particularly

S. No.	Vulnerability Details
	session and authentication cookies, with the Secure attribute. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 12).**
23.	**Use of HttpOnly Cookies** During the security assessment, it was observed that one or more cookies used by the application are not configured with the HttpOnly attribute. The HttpOnly attribute helps protect cookies by preventing client-side scripts, such as JavaScript, from accessing them. To mitigate this issue, it is strongly recommended to configure all sensitive cookies, particularly session and authentication cookies, with the HttpOnly attribute. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 13).**
24.	**Use of Non-Persistent Cookies For Tracking Session** It has been observed that the application configures cookies with the attribute SameSite=none. While this provides moderate protection against CSRF attacks, it still allows cookies to be sent in certain cross-site navigation scenarios. For enhanced security, especially to mitigate CSRF risks, it is recommended to configure cookies with SameSite=Strict, ensuring that cookies are only sent in a first-party context. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 14).**
25.	**Session Timeout** During the security assessment, it was observed that a session timeout policy is not implemented. User sessions remain active for an extended period of inactivity instead of expiring automatically. The absence of a session timeout mechanism increases the risk of unauthorized access, particularly in scenarios involving unattended or shared systems. To address this issue, it is recommended to implement an inactivity-based session timeout; invalidate sessions upon logout; regenerate session identifiers after authentication; and define timeout values in accordance with organizational security policies and industry best practices.
26.	**Contents of Cookies** During the security assessment, it was observed that multiple cookies are generated and used by the application for maintaining user sessions, authentication, user preferences, and other application functionalities. Provide an explanation of all cookies used by the application, including their purpose, contents, and associated security attributes. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 15).**
27.	**Insecure or Improper "Content-Security-Policy" header** During the security assessment, it was observed that the Content-Security-Policy (CSP) header is not configured securely (for example: Content-Security-Policy: object-src 'self'; img-src 'self'; frame-src 'self). The current policy is incomplete and does not adequately restrict the execution of scripts or other active content. An improperly configured CSP may allow attackers to exploit client-side vulnerabilities such as cross-site scripting (XSS), which could lead to the theft of sensitive user information or unauthorized actions within the application. It may also aid in information disclosure and increase the overall attack surface of the application. To address this issue, it is recommended to configure the server to enforce a strict and comprehensive Content-Security-Policy that limits the sources of executable scripts, styles, and other resources, and disables unnecessary content types. Recommended Configuration: Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'self'; object-src 'none';

S. No.	Vulnerability Details
	img-src 'self'; frame-src 'self'; base-uri 'self'; frame-ancestors 'self'. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 16).**
28.	**Missing Expires Header in HTTP Response** During the security assessment, it was observed the application responses did not include an Expires HTTP response header. The Expires header is used to specify the date and time after which a cached response should be considered stale. In the absence of appropriate cache-control directives, browsers and intermediary caches may store application responses for longer than intended. To address this issue, it is recommended to review and appropriately configure the expiration period of all cookies based on their purpose and sensitivity. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 17).**
29.	**Broken Access Control: Insecure Direct Object Reference (IDOR)** During the security assessment, an Insecure Direct Object Reference (IDOR) vulnerability was identified. It was observed that by modifying the username parameter in the request, the application returned data without performing proper authorization checks. For example, when the value of the userid parameter was changed from: userid: "2e23ed22-c3d3-457f-8362-d7263c9fa06d" to userid: "2e23ed22-c3d3-457f-8362-d7263c9fa08d" the application returned the same data, indicating that access control checks were not enforced on the server side. This behavior demonstrates a Broken Access Control vulnerability, as unauthorized users may be able to access or manipulate data belonging to other users by simply altering request parameters. An attacker could exploit this issue to access sensitive information of other users, leading to data exposure, privacy violations, and potential regulatory non-compliance. To address this issue, it is strongly recommended to enforce proper server-side authorization checks for all user-controlled parameters; ensure that access to resources is validated against the authenticated user's permissions; avoid relying on client-supplied identifiers for access control decisions; and implement indirect object references or secure access tokens where applicable. **Refer Annexure 'A' - Snapshots of vulnerabilities observed (Sr. No. 18)**
30.	**Third party libraries** During the security assessment, it was observed that the submitted list of third-party dependencies includes multiple components with known security vulnerabilities and is not updated to the latest stable and supported release versions. The use of outdated or vulnerable third-party libraries increases the risk of exploitation and may negatively impact the overall security posture of the application. To address this issue, it is recommended to regularly review and update third-party dependencies to their latest stable versions; monitor vulnerability advisories and CVE disclosures for used components; remove unused libraries; and implement a dependency management and patching process as part of the secure development lifecycle. **Refer Annexure 'C'** (provided separately with this report).

Note:

- For further details, please refer the detailed HCL AppScan Standard report provided separately with this report.
- Client is required to submit closure actions on the defect/vulnerability/ Non-conformance reported within specified time frame. If the course of action is not received by lab within 3

month of issue report, the job will be treated as closed without any closure verification and final report will be issued.

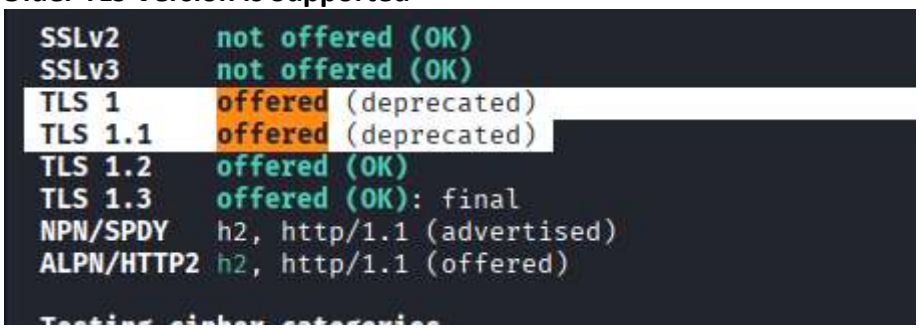
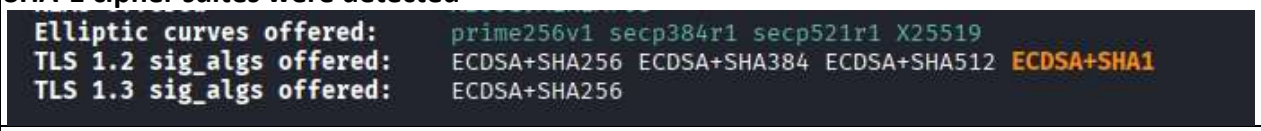
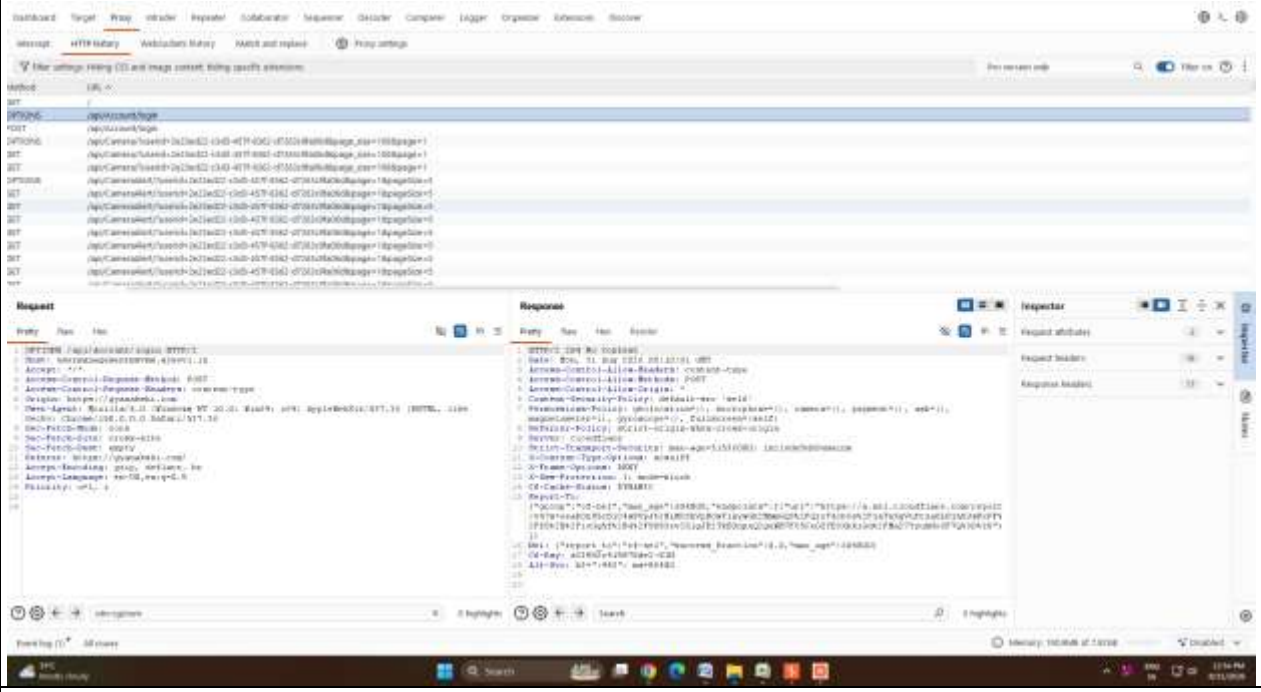
5.0: Approved & Released By:

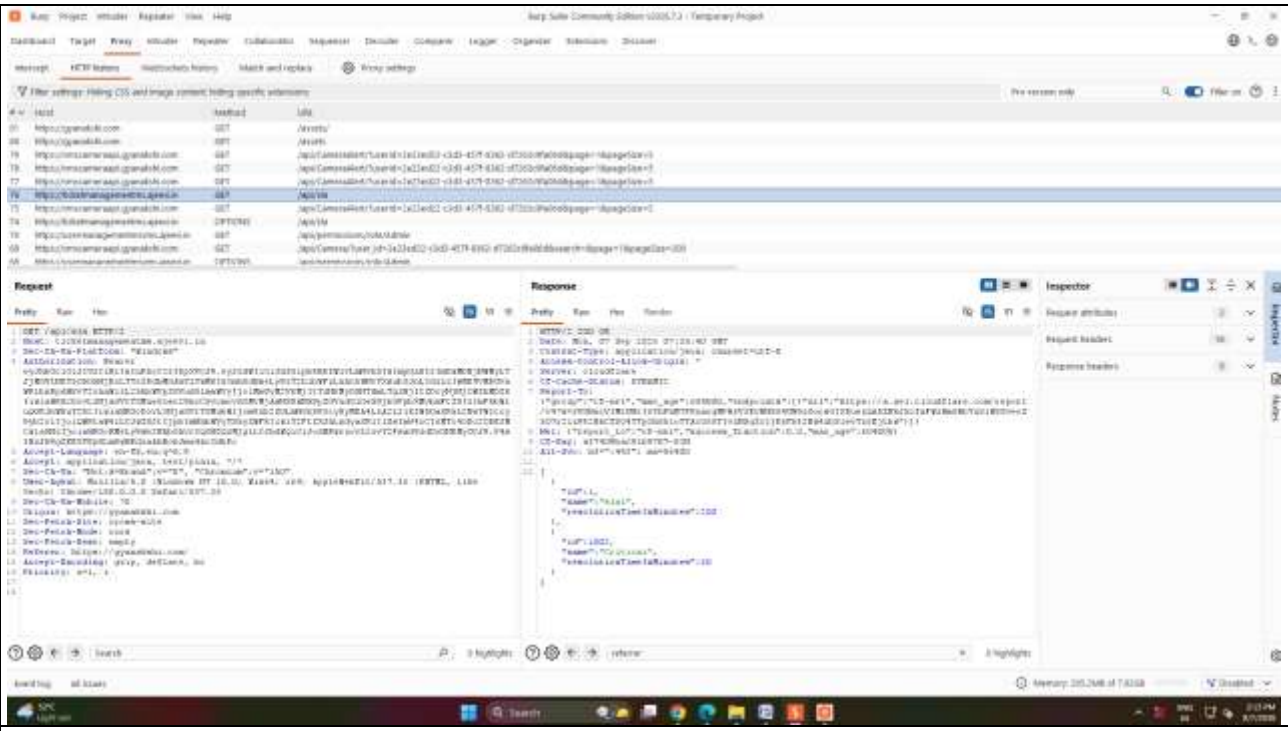
Dr. Manisha Rathee
(For QA)

Mr. Ramraj Meena
(For CSC)

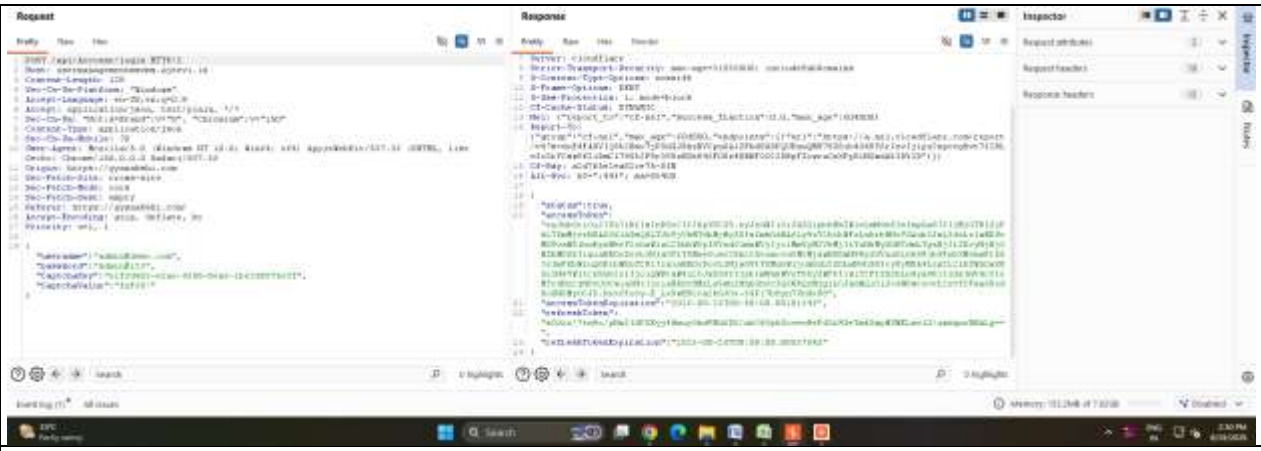
STQC IT -ERTL (North)
Dated: 28th Sept, 2026

Annexure 'A' - Snapshots of vulnerabilities observed

Sr. No.	Description
1	**Older TLS Version is Supported** 
2	**SHA-1 cipher suites were detected** 
3	**Missing HTTP Strict-Transport-Security Header** 
4	**Unnecessary HTTP Response Headers Disclosing Infrastructure Information** 
5	**Missing "Referrer policy" Security Header**



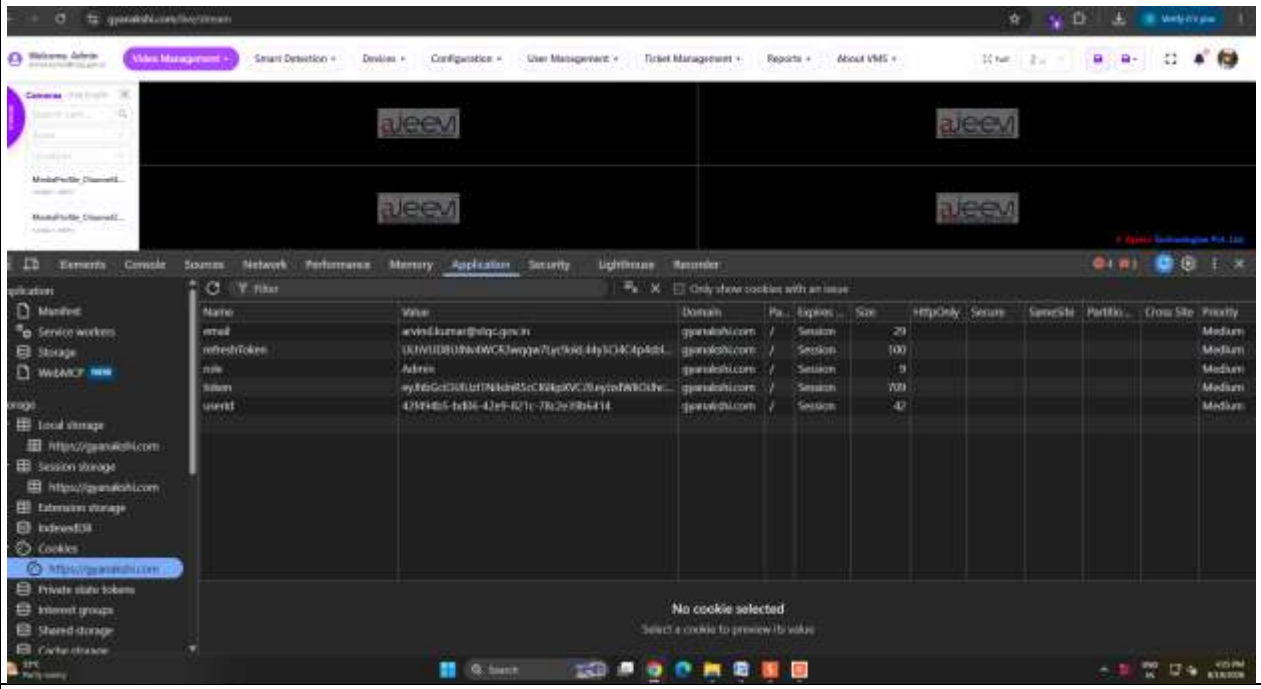
6	**Weak TLS Configuration: Obsolete CBC Cipher Suites Offered** Export ciphers (w/o ADH+NULL) not offered (OK) LOW: 64 Bit + DES, RC[2,4], MD5 (w/o export) not offered (OK) Triple DES Ciphers / IDEA not offered Obsoleted CBC ciphers (AES, ARIA etc.) offered Strong encryption (AEAD ciphers) with no FS not offered Forward Secrecy strong encryption (AEAD ciphers) offered (OK)
7	**BREACH Offered** Secure Client-Initiated Renegotiation not vulnerable (OK) CRIME, TLS (CVE-2012-4929) not vulnerable (OK) BREACH (CVE-2013-3587) potentially NOT ok, "br gzip" HTTP compression detected. - only supplied "/login" tested Can be ignored for static pages or if no secrets in the page POODLE, SSL (CVE-2014-3566) not vulnerable (OK), no SSLv3 support
8	**BEAST Offered** DROWN (CVE-2016-0800, CVE-2016-0703) not vulnerable on this host and port (OK) no RSA certificate, thus certificate can't be used with SSLv2 elsewhere LOGJAM (CVE-2015-4000), experimental not vulnerable (OK): no DH EXPORT ciphers, no DH key detected with <= TLS 1.2 BEAST (CVE-2011-3389) TLS1: ECDHE-ECDSA-AES128-SHA ECDHE-ECDSA-AES256-SHA VULNERABLE -- but also supports higher protocols TLSv1.1 TLSv1.2 (likely mitigated) LUCKY13 (CVE-2013-0169), experimental potentially VULNERABLE, uses obsolete cipher block chaining ciphers with TLS, see server prefs. Winshock (CVE-2014-6321), experimental not vulnerable (OK) RC4 (CVE-2013-2566, CVE-2015-2808) no RC4 ciphers detected (OK)
9	**LUCKY13 Offered** DROWN (CVE-2016-0800, CVE-2016-0703) not vulnerable on this host and port (OK) no RSA certificate, thus certificate can't be used with SSLv2 elsewhere LOGJAM (CVE-2015-4000), experimental not vulnerable (OK): no DH EXPORT ciphers, no DH key detected with <= TLS 1.2 BEAST (CVE-2011-3389) TLS1: ECDHE-ECDSA-AES128-SHA ECDHE-ECDSA-AES256-SHA VULNERABLE -- but also supports higher protocols TLSv1.1 TLSv1.2 (likely mitigated) LUCKY13 (CVE-2013-0169), experimental potentially VULNERABLE, uses obsolete cipher block chaining ciphers with TLS, see server prefs. Winshock (CVE-2014-6321), experimental not vulnerable (OK) RC4 (CVE-2013-2566, CVE-2015-2808) no RC4 ciphers detected (OK)
10	**Communication of credentials to back-end servers (DB/LDAP)**



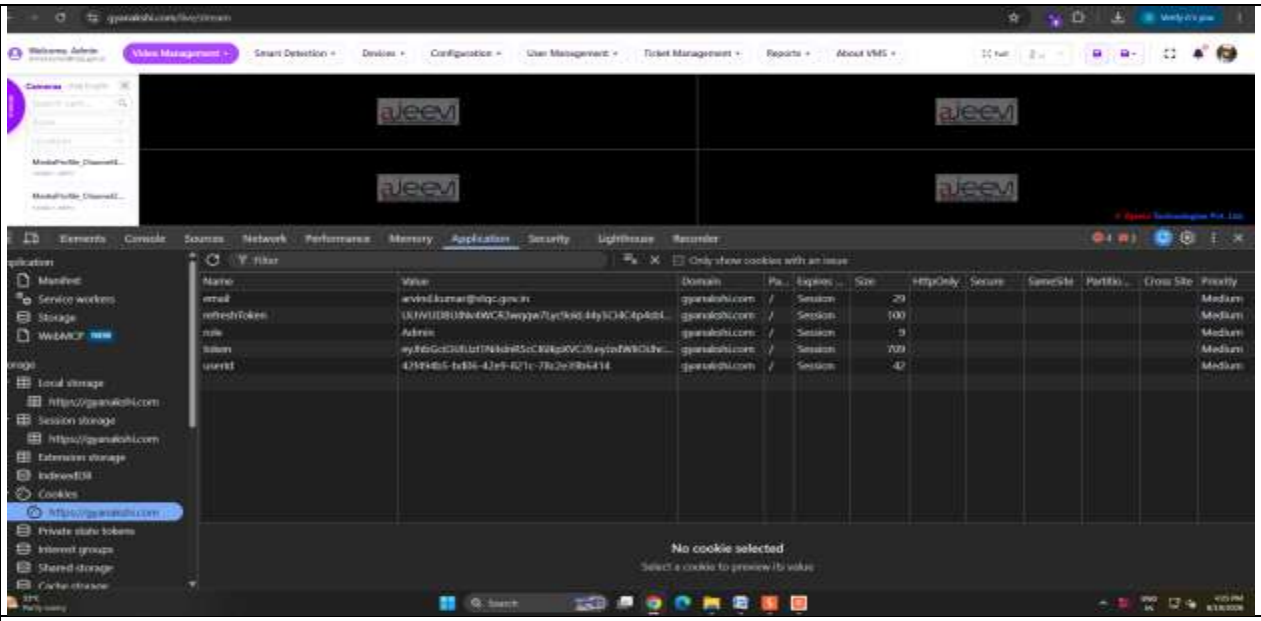
11 **Randomness of Session Token**



12 **Use of Secure Cookies**



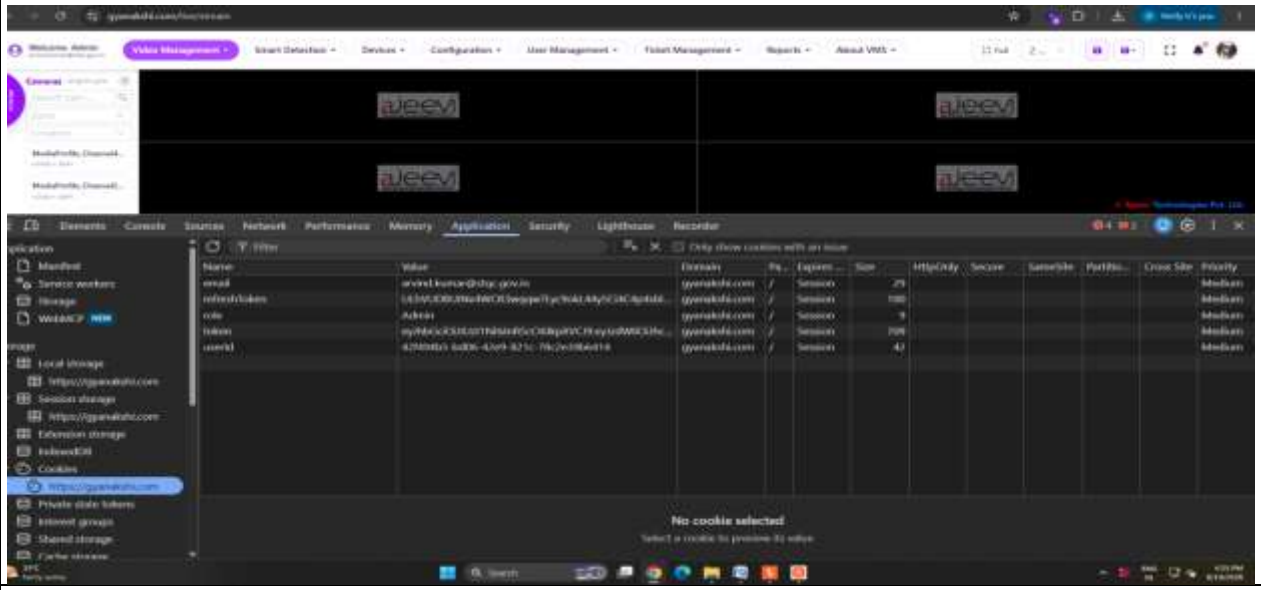
13 **Use of HttpOnly Cookies**



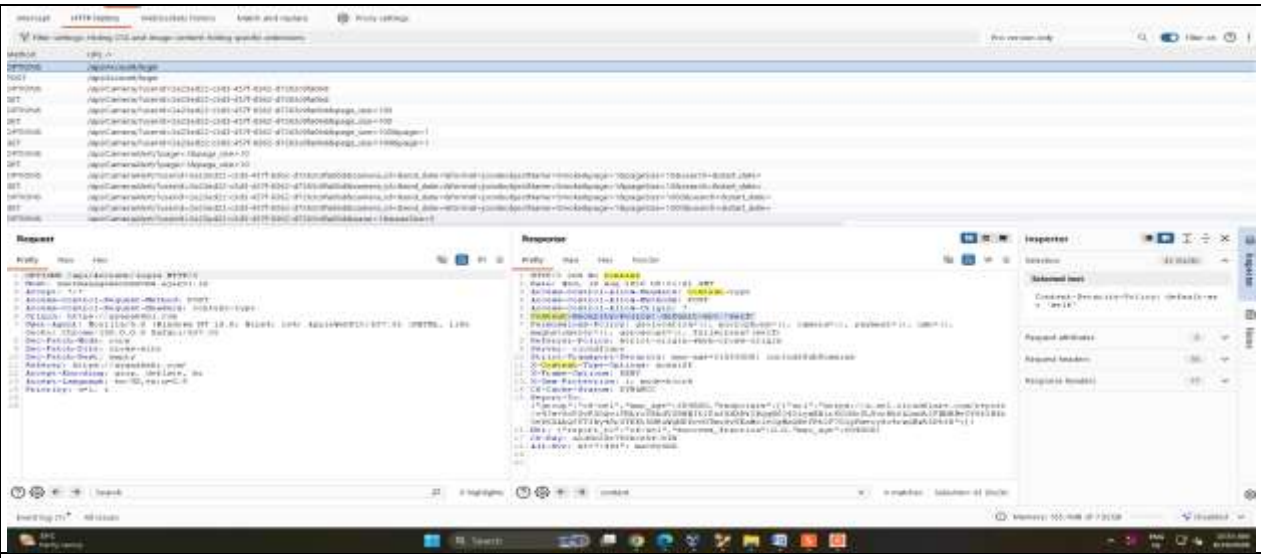
14	**Use of Non-Persistent Cookies For Tracking Session**

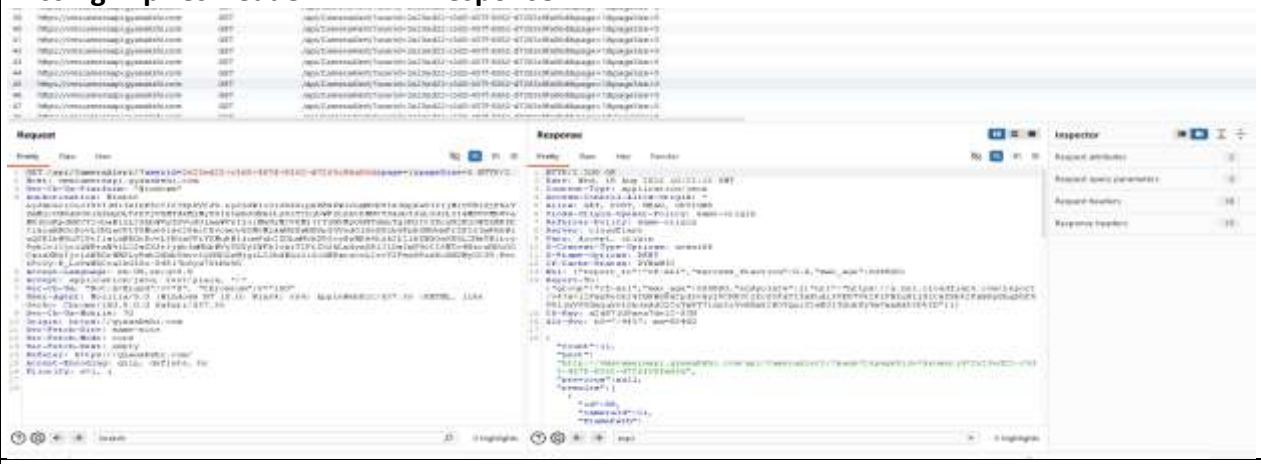


15	**Contents of Cookies**



16	**Insecure or Improper "Content-Security-Policy" header**



17	**Missing Expires Header in HTTP Response** 
18	**Broken Access Control: Insecure Direct Object Reference (IDOR)** In GET /api/Camera/?userid=2e23ed22-c3d3-457f-8362-d7263c9fa06d&page=1&pageSize=100 HTTP/2, when the value of the userid parameter was changed from: userid: "2e23ed22-c3d3-457f-8362-d7263c9fa06d" to userid: "2e23ed22-c3d3-457f-8362-d7263c9fa08d" the application returned the same data, indicating that access control checks were not enforced on the server side.

